

RMF Assessment:

The State Institute of Science and Technology

Monitor Task#1:

1. ISCM Strategy for SIST Web Infrastructure (SWI)

The Information Security Continuous Monitoring (ISCM) strategy for SIST Web Infrastructure (SWI) aims to maintain continuous awareness of the security posture within its High-Impact hybrid environment (AWS + SIST Data Center). In accordance with NIST SP 800-137, the strategy is to monitor vulnerabilities, configuration changes, and controls. The SWI system is important because it handles sensitive government information, including PII, financial data, and vulnerability data.

The ISCM strategy will utilize the AWS native logging and monitoring capabilities that have been previously implemented under AU-2 (Audit events), which includes AWS CloudTrail, Amazon CloudWatch, and Amazon S3 for log storage. The outputs from the monitoring of the system will be continuously evaluated by the security Operations Center (SOC) and ISSO to provide decision-makers with information to determine whether there is a degradation of control effectiveness to maintain the Authority to Operate (ATO) remains constant under changing conditions.

a) Five key security metrics from the SWI System

1. S3 Public Access Status
2. Critical Vulnerability Count per Asset
3. Unauthorized Configuration Change Frequency
4. Failed Authentication Attempts
5. Audit log Integrity and Retention Compliance

b) Monitoring/altering/reporting tools

1. AWS CloudTrail
2. Amazon CloudWatch Logs
3. AWS Config

c) Roles and responsibilities

1. Claire Jensen – Chief Information Security officer (CISO)
2. Jens Martensson – System Owner
3. April Hansson – Information System Security officer (ISSO)
4. Erik Lund – Security Operations Center (SOC) Manager

d) Monitoring frequency and reports

1. Vulnerability Scans: Weekly and Monthly
2. Real time monitoring: Continuous (24/7)

3. Reports: Daily (SOC), Weekly (ISSO), Monthly (CISO)
2. The most important risk Tier for the SWI system is Tier 3 – Information System Level as defined in the NIST SP 800-137 because high impact system where risk occur directly at the system level and monitoring tools operate at his level.
3. The CISO is the most responsible role because according to NIST SP 800-37 she is responsible for risk management and making sure security controls are implemented.

Monitor Task#2:

1. Yes, the SWI system will require reauthorization because of the decommissioning of Azure and infrastructure migration which are major changes to the system boundaries (NIST SP 800-37).
2. New Risk and Vulnerabilities
 - Cloud and Data Center Misconfiguration risk
 - Loss of Azure Inherited controls
 - Expanded Attack Surface
 - Insider Threat
 - Data Migration risk
3. Changes to SSP and POA&M

SSP updates:

 - Update system boundaries (remove Azure, include datacenter assets)
 - Revise architecture diagrams and data flows
 - Update inventory of hardware and software
 - Update common control providers (remover Azure, retain AWS, Zscaler, SISTNet, Equonix)

POA&M updates:

- Add findings related to migration risks and missing controls
- Track remediation actions (AWS/Data center configurations)
- Add timeline for re-implementing inherited controls previously provides by Azure

Monitor task #3:

Assumptions

- SWI remains a high impact system
- Hybrid environment (ASW + Data center) continues
- Zscaler remains a common control provider authentication and remote access

1. Recommendation: Automated configuration compliance monitoring with the use of AWS configuration to guarantee continuous enforcement of safe configuration which is crucial in high impact cloud environment.
2. Recommendation: Enhance identity and access management controls in AWS and Data center environments because with Azure removed and while using IAM and Zscaler, it can avoid unauthorized access .
3. Recommendation: Enhance centralized logging and SIEM integration with using GMAT.

References

National Institute of Standards and Technology. (2011). Information Security Continuous Monitoring (ISCM) for Federal Information Systems and Organizations (NIST SP 800-137). <https://nvlpubs.nist.gov/nistpubs/legacy/sp/nistspecialpublication800-137>

National Institute of Standards and Technology. (2020). Security and Privacy Controls for Information Systems and Organizations (NIST SP 800-53 Rev. 5). <https://doi.org/10.6028/NIST.SP.800-53r5>

National Institute of Standards and Technology. (2018). Risk Management Framework for Information Systems and Organizations (NIST SP 800-37 Rev. 2). <https://doi.org/10.6028/NIST.SP.800-37r2>

Amazon Web Services. (2024). AWS CloudTrail User Guide. <https://docs.aws.amazon.com/cloudtrail/>

Amazon Web Services. (2024). Amazon CloudWatch User Guide. <https://docs.aws.amazon.com/cloudwatch/>

Amazon Web Services. (2024). Amazon S3 User Guide. <https://docs.aws.amazon.com/s3/>